ISO 27001

Seguridad de la Información – ISO 27001

Política de Controles de Organización

Esteban Chamblat Rojas

TABLA DE CONTENIDO

1. OBJETIVO
2. ALCANCE
3. RESPONSABILIDADES
4. DESCRIPCIÓN DEL PROCESO
    - 4.1 Solicitud de Acceso
    - 4.2 Aprobación y Concesión
    - 4.3 Revisión Periódica de Accesos
    - 4.4 Revocación y Modificación
5. CONTROL DE ACCESO LÓGICO
    - 5.1 Autenticación y MFA
    - 5.2 Gestión de Identidades en OpenTux

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Información del Documento	**Detalle**
Autor del Documento	Esteban Chamblat
Fecha de Creación	18/01/2025
Clasificación	Uso Interno / Confidencial

HISTORIA DE VERSIONES

Versión	**Fecha**	**Descripción**	**Autor**
1.0	**14/05/2025**	**Creación de documento**	**Esteban Chamblat**

---

1. OBJETIVO

Establecer los pasos necesarios para asegurar que el acceso a los sistemas, aplicaciones y datos de Pepito paga doble esté restringido únicamente a usuarios autorizados, basándose en el principio de necesidad de saber y mínimo privilegio.

2. ALCANCE

Este procedimiento aplica a todos los colaboradores, contratistas y terceros que requieran acceso a la infraestructura técnica de la empresa, incluyendo nodos de virtualización Proxmox VE, orquestadores Docker Swarm, bases de datos PostgreSQL y servidores Rocky Linux.

3. RESPONSABILIDADES

- Esteban Chamblat (Responsable de SI): Supervisar la correcta ejecución de este procedimiento y validar las revisiones trimestrales.
- Líderes de Área: Autorizar formalmente las solicitudes de acceso para sus respectivos equipos.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

- Unidad de TI: Ejecutar técnicamente el alta, baja o modificación de usuarios en el directorio central OpenTux.

4. DESCRIPCIÓN DEL PROCESO

4.1 Solicitud de Acceso

Toda nueva cuenta o perfil debe solicitarse mediante los canales oficiales. La solicitud debe especificar el rol del usuario y los activos específicos (ej. bases de datos de producción o contenedores específicos) a los que requiere entrar.

4.2 Aprobación y Concesión

Una vez aprobada la solicitud por el jefe directo, la Unidad de TI procederá a crear la identidad en OpenTux. Se prohíbe el uso de cuentas compartidas o genéricas para tareas de administración en el stack de servidores.

4.3 Revisión Periódica de Accesos

Cada tres meses se realizará un inventario de privilegios. Cualquier acceso que no esté debidamente justificado o que no haya sido utilizado en los últimos 90 días será desactivado preventivamente.

4.4 Revocación y Modificación

En caso de desvinculación, el acceso a la red y a los sistemas (VPN, pfSense, PostgreSQL) debe ser revocado de forma inmediata (en un plazo no mayor a 2 horas tras la notificación).

5. CONTROL DE ACCESO LÓGICO

5.1 Autenticación y MFA

Para acceder a la infraestructura crítica, es obligatorio el uso de MFA Corporativo. El firewall pfSense gestiona las conexiones VPN, exigiendo un certificado digital y un segundo factor de autenticación.

5.2 Gestión de Identidades en OpenTux

OpenTux actúa como la fuente única de verdad para la identidad. Los derechos de acceso a los sistemas operativos Rocky Linux se gestionan mediante grupos de seguridad, asegurando una trazabilidad completa de quién accede y cuándo.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*